Incident Report — Storm-0501: Azure Storage Account Key Abuse and Cloud Ransom

SOC Analysis & Triage · Advanced Operation

1. Header / Metadata

Operation ID	OPS-2026-0519-12
Operation name	Storm-0501: Azure Storage Account Key Abuse and Cloud Ransom
Started (UTC)	2026-05-19 01:12:39
Closed (UTC)	2026-05-19 06:14:47
Analyst	Ndumiso Mbanjwa
Cohort	May26 Cybersecurity
Difficulty	Advanced
Severity	Critical
Final verdict	True Positive
Status	Closed – Escalated for federation-trust removal, storage key rotation, breach assessment on 768 GB egress and recovery planning without backups

2. Executive Summary

This was a cloud-native ransomware operation against the hybrid Microsoft Entra ID tenant of Kaldberg Logistics, carried out entirely through the Azure control plane. No encryptor binary ever ran and no endpoint was infected. In five hours the operator took over the tenant, planted persistence that survives password resets, stole 768 GB of freight data, destroyed the means of recovery, re-encrypted what remained with a key the company does not hold, and posted an extortion message in Microsoft Teams from an impersonated employee's account.

The entry point was svc-aadc-sync, the Entra Connect directory-synchronisation service account. It holds Global Administrator, it is exempt from MFA, and it should never sign in interactively at all — yet at 01:12:39 it authenticated from 109.100.14[.]222 with no MFA challenge. Fifty-three minutes later it added kaldberg-sync-trust[.]com to the tenant as a federated domain with an attacker-supplied token-signing certificate. That single configuration change is the most serious action in the

whole case: a federation trust mints SAML tokens for any user in the directory, so from that moment the operator could become anyone, and resetting passwords would not have stopped them. It was used at 02:31:18 to sign in as harriet.voss from 14.103.118[.]198, and again at 06:14:47 to post the ransom message in Teams from 1.214.214[.]114.

The data-plane theft followed the same logic. Having assigned itself Owner over the subscription at 02:21:52, the operator listed the storage account keys — shared keys that Azure role-based access control does not govern, so anyone holding them can read every blob directly. Between 03:22 and 04:51 the freight-archive container was bulk-read with AuthenticationType=SharedKey from 103.191.14[.]243 using AzCopy 10.25.1, about 768 GB egressed. At 05:52:10 Defender for Cloud recorded the endgame: snapshots, restore points and the Recovery Services vault rsv-kaldberg-dr-ne deleted, and a customer-managed key in an attacker-controlled key vault applied to kaldbergprodblob01. Destroying recovery before changing the encryption is what converts an outage into leverage. All 8 scored tasks were resolved and this was the first completion of the operation on the platform.

3. Operation Details

Triggering detection	Five Critical rules fired: directory-sync identity signing in interactively; federated domain added to the tenant; tenant access elevation / subscription Owner assignment; storage key listing followed by SharedKey external read; backup destruction preceding storage encryption change
Source	109.100.14[.]222 (initial sign-in, RO), 14.103.118[.]198 (SAML impersonation, CN), 103.191.14[.]243 (AzCopy exfiltration, ID), 1.214.214[.]114 (Teams extortion, KR)
Destination	Entra ID tenant kaldberg-logistics.com; subscription a3f7c901-5e24-4b86-9d1f-72c0e8b43a16; storage account kaldbergprodblob01, container freight-archive
User / Host affected	svc-aadc-sync (Entra Connect sync identity, Global Administrator, no MFA); harriet.voss (impersonated via the federation trust)
Artefact	Federated domain kaldberg-sync-trust[.]com with attacker token-signing certificate; storage account shared keys; AzCopy/10.25.1 Azure-Storage/0.16 (go1.22; Windows_NT); deleted vault rsv-kaldberg-dr-ne; attacker customer-managed key
Direction	Inbound control-plane authentication from four external addresses; outbound ~768 GB data egress over the storage data plane
Tool surfaces used	Security log platform (SIEM) and cloud telemetry (CLOUD) — Azure Activity Log, storage diagnostics, Entra sign-in and audit

	logs, Defender for Cloud

4. Investigation & Triage

Task	Objective	What I checked	Finding	Decision & reasoning	Fig. ref
Task 1 – Incident brief	Establish the scope before touching telemetry	The reported position: a hybrid Entra ID tenant, ransom demand received, no encryptor binary found on any endpoint	A cloud-native extortion case to be reconstructed from Azure Activity Log, storage diagnostics and Entra sign-in telemetry	"No binary" reframes the investigation: the evidence is control-plane configuration changes and API calls, not files on disk	Fig. 1
Task 2 – Identify the identity that opened the cloud	Find the first malicious authentication	Entra sign-in telemetry in the small hours, before any administrator was working	01:12:39, Critical: interactive sign-in succeeded for svc-aadc-sync@kaldberg-logistics.com, holding Global Administrator, from external address 109.100.14[.]222, with NO MFA challenge	svc-aadc-sync is the Entra Connect directory-synchronisation identity. It runs a background sync and has no legitimate reason ever to sign in interactively, least of all from the internet at 01:12 without MFA	Fig. 2, 3
Task 3 – Find the cloud persistence backdoor	Identify persistence that a password reset cannot undo	Entra audit records in the minutes after the sign-in	02:05:41, Critical: svc-aadc-sync set domain authentication to 'Federated' for kaldberg-sync-trust[.]com, supplying an attacker-controlled token-signing certificate	A federated domain lets the holder mint SAML tokens for any user in the tenant. This is the worst finding in the case: credentials become irrelevant, and the trust persists until it is explicitly removed	Fig. 3
Task 4 – Classify the	Map the move from	The Activity Log call that	T1528 Steal Application Access	Storage account keys sit outside	Fig. 3

Task	Objective	What I checked	Finding	Decision & reasoning	Fig. ref
data-plane key abuse	control plane to data plane	returned the storage account's shared access keys, read together with the bulk read that followed	Token. Owner rights at subscription scope were assigned at 02:21:52, then a single listKeys operation returned the account keys, and the next activity is a SharedKey-authenticated read	Azure RBAC: whoever holds them reads and writes every blob directly. Listing the keys is the moment a management role becomes a credential for the data itself	
Task 5 – Pin the exfiltration channel	Identify the address that took the data	Storage analytics for the freight-archive container	04:55:00, Critical: container freight-archive bulk-read with AuthenticationType =SharedKey from 103.191.14[.]243, ua="AzCopy/10.25. 1 Azure-Storage/0.16 (go1.22; Windows_NT)", between 03:22 and 04:51; ~768 GB egressed	AuthenticationType =SharedKey proves the stolen keys were used rather than a user token, and the AzCopy agent string identifies the bulk-copy tool. The address is 103.191.14[.]243	Fig. 4
Task 6 – Establish the recovery-destruction step	Name what was destroyed to prevent recovery	The Defender for Cloud alert covering the destruction window	05:52:10, Critical: snapshots, restore points and the Recovery Services vault rsv-kaldberg-dr-ne deleted on subscription a3f7c901-5e24-4b86-9d1f-72c0e8b43a16, immediately before the encryption change	The vault is the answer: rsv-kaldberg-dr-ne. Deleting recovery first is deliberate sequencing — it removes the option to restore and makes the encryption change a negotiating position rather than an inconvenience	Fig. 4

Task	Objective	What I checked	Finding	Decision & reasoning	Fig. ref
Task 7 – Classify the cloud encryption-for-impact	Map the encryption step to ATT&CK	The same Defender for Cloud alert: a customer-managed key in an attacker key vault applied to kaldbergprodblob01	T1486 Data Encrypted for Impact. The data was re-encrypted in place through Azure's own encryption-scope mechanism, with no ransomware binary involved	The technique is unchanged even though the delivery is not. Recognising T1486 without an encryptor is the point of the case: the cloud provider's key management was used as the encryption tool	Fig. 4
Task 8 – Attribute the extortion message	Identify the account used to deliver the ransom demand	Entra sign-in telemetry for Microsoft Teams after the encryption change	06:14:47, High: sign-in to Microsoft Teams as harriet.voss from external address 1.214.214[.]114; a ransom message was posted minutes later. The same identity was impersonated at 02:31:18 via the federation trust	The message came from harriet.voss, but she did not send it — the SAML backdoor minted the token. Attribution here means naming the identity and showing it was forged, so an innocent employee is not treated as an insider	Fig. 5

5. Threat Intelligence

Indicator (defanged)	Tool	Result / score	Date checked (UTC)	Notes
109.100.14[.]222	VirusTotal	9 of 89 vendors flagged it (BitDefender, G-Data, Sophos, VIPRE, alphaMountain as Phishing; Certego, Chong Lua Dao, SOCRadar as	2026-09-19	The address behind the initial no-MFA Global Administrator sign-in. Independent confirmation that the entry point came from known-bad infrastructure, not a

Indicator (defanged)	Tool	Result / score	Date checked (UTC)	Notes
		Malicious). AS 9050 Orange Romania S.A., RO		misconfigured internal job.
14.103.118[.]198	VirusTotal	8 of 89 vendors flagged it (GreenSnow, GreyNoise, IPsum, Lionic, Chong Lua Dao as Malicious; BitDefender, G-Data as Phishing). AS 4811 China Telecom (Group), CN	2026-09-19	Used for the federated sign-in impersonating harriet.voss. A different country and provider from the initial access address, which is why the federation trust matters more than any single IP block.
103.191.14[.]243	VirusTotal	10 of 89 vendors flagged it (Fortinet and VIPRE as Malware; ADMINUSLabs, GreenSnow, GreyNoise, IPsum, Lionic as Malicious; BitDefender, G-Data, SOCRadar as Phishing). AS 38513 PT Aplikanusa Lintasarta, ID	2026-09-19	The AzCopy exfiltration endpoint that received roughly 768 GB from the freight-archive container. The highest-value block of the four, since it is where the data actually went.
1.214.214[.]114	VirusTotal	11 of 89 vendors flagged it (Fortinet as Malware; ADMINUSLabs, GreenSnow, GreyNoise, IPsum, Lionic, Chong Lua Dao as Malicious). AS 3786 LG DACOM Corporation, KR	2026-09-19	The address behind the Teams sign-in that delivered the extortion message. Four addresses across four countries indicates rented or compromised infrastructure rotated per stage.

Indicator (defanged)	Tool	Result / score	Date checked (UTC)	Notes
kaldberg-sync-trust[.]com	VirusTotal	0 of 89 vendors flag it; VirusTotal applies only a “dga” tag	2026-09-19	The most important indicator in the case has no reputation at all. Its danger comes entirely from what it was configured to be — a federated domain inside the tenant — which no external feed can see. Reputation lookups would never have surfaced it.

This is assessed with high confidence as a Storm-0501-style cloud ransomware operation: identity-led, control-plane only, with extortion rather than encryption of endpoints. The external addresses are all independently flagged as malicious, which corroborates the timeline but adds nothing that the tenant's own records did not already prove. The reverse is more instructive: the single most damaging artefact, the federated domain kaldberg-sync-trust[.]com, is unflagged by every vendor, because a domain used as a SAML issuer looks like nothing from outside. Detection here depends on watching configuration state — who signs in interactively, what domains are federated, who holds Owner, when keys are listed — rather than on matching indicators against feeds. The scenario's premise that no encryptor binary exists is borne out by the telemetry: every impact action is an Azure API call.

6. Timeline (UTC)

Time (UTC)	Event
2026-05-19 01:12:39	Critical — interactive sign-in by svc-aadc-sync (Global Administrator) from 109.100.14[.]222, no MFA challenge (T1078.004)
2026-05-19 02:05:41	Critical — domain authentication set to Federated for kaldberg-sync-trust[.]com with attacker token-signing certificate (T1484.002)
2026-05-19 02:21:52	High — svc-aadc-sync assigns itself Owner at subscription scope a3f7c901-5e24-4b86-9d1f-72c0e8b43a16 (T1098.003)
2026-05-19 02:31:18	High — federated sign-in impersonating harriet.voss via issuer kaldberg-sync-trust[.]com from 14.103.118[.]198 (T1606.002)
2026-05-19 ~02:4x	Storage account keys listed via the Azure control plane, converting a management role into data-plane access (T1528)

Time (UTC)	Event
2026-05-19 03:22–04:51	Bulk read of container freight-archive with AuthenticationType=SharedKey from 103.191.14[.]243 using AzCopy/10.25.1; ~768 GB egressed (T1537)
2026-05-19 04:55:00	Critical — storage analytics records the completed bulk-read and the volume egressed
2026-05-19 05:52:10	Critical — snapshots, restore points and Recovery Services vault rsv-kaldberg-dr-ne deleted, then a customer-managed key in an attacker key vault applied to kaldbergprodblob01 (T1490, T1486)
2026-05-19 06:14:47	High — Teams sign-in as harriet.voss from 1.214.214[.]114; ransom message posted minutes later (T1657)

7. Indicators of Compromise

Type	Indicator (defanged)	Context
Account	svc-aadc-sync@kaldberg-logistics.com	Entra Connect sync identity, Global Administrator, MFA-exempt; used for initial access — platform Confirmed finding
Domain	kaldberg-sync-trust[.]com	Attacker-controlled federated domain minting SAML tokens for any user — platform Confirmed finding
IPv4	109.100.14[.]222	Initial no-MFA Global Administrator sign-in; VirusTotal 9/89
IPv4	14.103.118[.]198	Federated sign-in impersonating harriet.voss; VirusTotal 8/89
IPv4	103.191.14[.]243	AzCopy SharedKey bulk read, ~768 GB — platform Confirmed finding; VirusTotal 10/89
IPv4	1.214.214[.]114	Teams sign-in that delivered the ransom message; VirusTotal 11/89
User agent	AzCopy/10.25.1 Azure-Storage/0.16 (go1.22; Windows_NT)	Bulk-copy tool used for the exfiltration
Azure resource	rsv-kaldberg-dr-ne	Recovery Services vault deleted before the encryption change — platform Confirmed finding
Azure resource	kaldbergprodblob01	Storage account whose keys were listed and which was re-encrypted with an attacker key

Type	Indicator (defanged)	Context
Azure resource	freight-archive	Container bulk-read over the data plane
Subscription	a3f7c901-5e24-4b86-9d1f-72c0e8b43a16	Scope of the Owner assignment and of the backup destruction
Identity	harriet.voss	Impersonated via the federation trust and used to post the extortion message — platform Confirmed finding

STIX 2.1 Bundle


```
{
    "type": "bundle",
    "id": "bundle--9bf4a317-79de-5701-963f-dc6f2e9572d8",
    "objects": [
        {
            "type": "identity",
            "spec_version": "2.1",
            "id": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Ndumiso Mbanjwa (May26 Cybersecurity)",
            "description": "SOC analyst incident report \u2014 May26 Cybersecurity cohort,
SOC Simulator operation Storm-0501: Azure Storage Account Key Abuse and Cloud Ransom.",
            "identity_class": "individual",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "tool",
            "spec_version": "2.1",
            "id": "tool--042bf938-785b-5565-875a-e697a27cc907",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "AzCopy",
            "description": "Microsoft bulk data-transfer utility, version 10.25.1, used
with stolen storage account shared keys to egress ~768 GB from the freight-archive
container to 103.191.14.243.",
            "tool_types": [
                "data-exfiltration"
            ],
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "tool",
            "spec_version": "2.1",
            "id": "tool--1e556f06-c094-542c-8a3a-0f67c8c38b25",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Federated domain SAML backdoor",
            "description": "Persistence created by setting kaldberg-sync-trust.com as a
```

```
federated domain with an attacker-supplied token-signing certificate, allowing SAML tokens
to be minted for any identity in the tenant.",
            "tool_types": [
                "credential-exploitation"
            ],
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "attack-pattern",
            "spec_version": "2.1",
            "id": "attack-pattern--7ee57f6c-1107-509c-9c74-9df3bca9200a",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Valid Accounts: Cloud Accounts",
            "description": "Reuse of the synced svc-aadc-sync identity holding Global
Administrator without MFA (platform tag T1078.004).",
            "external_references": [
                {
                    "source_name": "mitre-attack",
                    "url": "https://attack.mitre.org/techniques/T1078/004/",
                    "external_id": "T1078.004"
                }
            ],
            "kill_chain_phases": [
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "initial-access"
                },
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "persistence"
                },
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "privilege-escalation"
                },
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "defense-evasion"
                }
            ],
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "attack-pattern",
            "spec_version": "2.1",
            "id": "attack-pattern--af6bf872-1727-5ced-9982-9fb37761075e",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Account Manipulation: Additional Cloud Roles",
            "description": "Owner role assigned at subscription scope a3f7c901-5e24-4b86-
9d1f-72c0e8b43a16 (platform tag T1098.001 family).",
            "external_references": [
```

```
                {
                    "source_name": "mitre-attack",
                    "url": "https://attack.mitre.org/techniques/T1098/003/",
                    "external_id": "T1098.003"
                }
            ],
            "kill_chain_phases": [
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "persistence"
                },
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "privilege-escalation"
                }
            ],
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "attack-pattern",
            "spec_version": "2.1",
            "id": "attack-pattern--dd8bc502-9b9e-5e70-a8e3-09fb831cd94f",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Domain or Tenant Policy Modification: Trust Modification",
            "description": "Domain authentication set to Federated for kaldberg-sync-
trust.com with an attacker token-signing certificate.",
            "external_references": [
                {
                    "source_name": "mitre-attack",
                    "url": "https://attack.mitre.org/techniques/T1484/002/",
                    "external_id": "T1484.002"
                }
            ],
            "kill_chain_phases": [
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "persistence"
                },
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "privilege-escalation"
                }
            ],
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "attack-pattern",
            "spec_version": "2.1",
            "id": "attack-pattern--d9fd513f-ae94-56de-aae6-d2670d38d693",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Steal Application Access Token",
```

```
            "description": "Platform-confirmed classification of the storage account
listKeys operation that produced data-plane credentials.",
            "external_references": [
                {
                    "source_name": "mitre-attack",
                    "url": "https://attack.mitre.org/techniques/T1528/",
                    "external_id": "T1528"
                }
            ],
            "kill_chain_phases": [
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "credential-access"
                }
            ],
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "attack-pattern",
            "spec_version": "2.1",
            "id": "attack-pattern--794369aa-e407-5e24-b060-a794440f0b76",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Forge Web Credentials: SAML Tokens",
            "description": "Federated sign-in impersonating harriet.voss via the attacker-
controlled issuer.",
            "external_references": [
                {
                    "source_name": "mitre-attack",
                    "url": "https://attack.mitre.org/techniques/T1606/002/",
                    "external_id": "T1606.002"
                }
            ],
            "kill_chain_phases": [
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "credential-access"
                },
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "lateral-movement"
                }
            ],
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "attack-pattern",
            "spec_version": "2.1",
            "id": "attack-pattern--56cae5d4-4526-557a-88d1-0d29cc318ec9",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Transfer Data to Cloud Account",
            "description": "~768 GB read from the freight-archive container with SharedKey
```

```
authentication via AzCopy (platform tag T1537).",
            "external_references": [
                {
                    "source_name": "mitre-attack",
                    "url": "https://attack.mitre.org/techniques/T1537/",
                    "external_id": "T1537"
                }
            ],
            "kill_chain_phases": [
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "exfiltration"
                }
            ],
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "attack-pattern",
            "spec_version": "2.1",
            "id": "attack-pattern--55824af3-77db-5dba-b57d-c374a4149113",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Inhibit System Recovery",
            "description": "Snapshots, restore points and the Recovery Services vault rsv-
kaldberg-dr-ne deleted before the encryption change.",
            "external_references": [
                {
                    "source_name": "mitre-attack",
                    "url": "https://attack.mitre.org/techniques/T1490/",
                    "external_id": "T1490"
                }
            ],
            "kill_chain_phases": [
                {
                    "kill_chain_name": "mitre-attack",
                    "phase_name": "impact"
                }
            ],
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "attack-pattern",
            "spec_version": "2.1",
            "id": "attack-pattern--41cb79c3-c416-5af4-be95-22c33948037a",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Data Encrypted for Impact",
            "description": "Platform-confirmed classification of the customer-managed key
in an attacker key vault applied to kaldbergprodblob01.",
            "external_references": [
                {
                    "source_name": "mitre-attack",
                    "url": "https://attack.mitre.org/techniques/T1486/",
```

```
                "external_id": "T1486"
            }
        ],
        "kill_chain_phases": [
            {
                "kill_chain_name": "mitre-attack",
                "phase_name": "impact"
            }
        ],
        "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
        "object_marking_refs": [
            "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
        ]
    },
    {
        "type": "attack-pattern",
        "spec_version": "2.1",
        "id": "attack-pattern--ec4d0835-c213-5e64-994f-33515295facb",
        "created": "2026-05-19T01:12:39.000Z",
        "modified": "2026-09-19T15:30:00.000Z",
        "name": "Financial Theft",
        "description": "Extortion message posted in Microsoft Teams from the
impersonated harriet.voss account.",
        "external_references": [
            {
                "source_name": "mitre-attack",
                "url": "https://attack.mitre.org/techniques/T1657/",
                "external_id": "T1657"
            }
        ],
        "kill_chain_phases": [
            {
                "kill_chain_name": "mitre-attack",
                "phase_name": "impact"
            }
        ],
        "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
        "object_marking_refs": [
            "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
        ]
    },
    {
        "type": "indicator",
        "spec_version": "2.1",
        "id": "indicator--459696f7-384e-5014-9160-d4cd81e3f745",
        "created": "2026-05-19T01:12:39.000Z",
        "modified": "2026-09-19T15:30:00.000Z",
        "name": "Initial access address",
        "description": "Interactive no-MFA Global Administrator sign-in by svc-aadc-
sync at 2026-05-19T01:12:39Z. VirusTotal 9/89, AS9050 Orange Romania (2026-09-19).",
        "indicator_types": [
            "malicious-activity"
        ],
        "pattern": "[ipv4-addr:value = '109.100.14.222']",
        "pattern_type": "stix",
        "valid_from": "2026-05-19T01:12:39.000Z",
        "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
        "object_marking_refs": [
            "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
```

```
            ]
        },
        {
            "type": "indicator",
            "spec_version": "2.1",
            "id": "indicator--0255d8b3-d471-5781-843b-f2ddf6c723e8",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "SAML impersonation address",
            "description": "Federated sign-in as harriet.voss at 2026-05-19T02:31:18Z.
VirusTotal 8/89, AS4811 China Telecom (2026-09-19).",
            "indicator_types": [
                "malicious-activity"
            ],
            "pattern": "[ipv4-addr:value = '14.103.118.198']",
            "pattern_type": "stix",
            "valid_from": "2026-05-19T01:12:39.000Z",
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "indicator",
            "spec_version": "2.1",
            "id": "indicator--57346138-43cb-5a92-9fed-c117a2b35b71",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Exfiltration endpoint",
            "description": "SharedKey bulk read of freight-archive 03:22-04:51Z, ~768 GB
via AzCopy 10.25.1. VirusTotal 10/89 (2026-09-19).",
            "indicator_types": [
                "malicious-activity"
            ],
            "pattern": "[ipv4-addr:value = '103.191.14.243']",
            "pattern_type": "stix",
            "valid_from": "2026-05-19T01:12:39.000Z",
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "indicator",
            "spec_version": "2.1",
            "id": "indicator--39a62398-2e32-52ea-b56a-c09766216c8e",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Extortion delivery address",
            "description": "Teams sign-in as harriet.voss at 2026-05-19T06:14:47Z
preceding the ransom message. VirusTotal 11/89 (2026-09-19).",
            "indicator_types": [
                "malicious-activity"
            ],
            "pattern": "[ipv4-addr:value = '1.214.214.114']",
            "pattern_type": "stix",
            "valid_from": "2026-05-19T01:12:39.000Z",
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
```

```
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "indicator",
            "spec_version": "2.1",
            "id": "indicator--6a759d8f-89f6-5ca4-a16d-dc3ee4083445",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Federation backdoor domain",
            "description": "Configured as a federated domain in the tenant at 2026-05-
19T02:05:41Z with attacker token-signing certificate. VirusTotal 0/89 (2026-09-19).",
            "indicator_types": [
                "malicious-activity"
            ],
            "pattern": "[domain-name:value = 'kaldberg-sync-trust.com']",
            "pattern_type": "stix",
            "valid_from": "2026-05-19T01:12:39.000Z",
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "indicator",
            "spec_version": "2.1",
            "id": "indicator--02493dc2-b244-5dc3-bde0-7736c9d1a20d",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Bulk exfiltration tooling",
            "description": "User agent AzCopy/10.25.1 Azure-Storage/0.16 (go1.22;
Windows_NT) recorded on the SharedKey reads.",
            "indicator_types": [
                "malicious-activity"
            ],
            "pattern": "[software:name = 'AzCopy']",
            "pattern_type": "stix",
            "valid_from": "2026-05-19T01:12:39.000Z",
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        },
        {
            "type": "indicator",
            "spec_version": "2.1",
            "id": "indicator--738c9efe-791c-5f2b-a50e-5a089c46a6da",
            "created": "2026-05-19T01:12:39.000Z",
            "modified": "2026-09-19T15:30:00.000Z",
            "name": "Compromised sync identity",
            "description": "Entra Connect directory-sync service identity holding Global
Administrator without MFA; signed in interactively, federated a domain and self-assigned
Owner.",
            "indicator_types": [
                "malicious-activity"
            ],
            "pattern": "[user-account:account_login = 'svc-aadc-sync']",
            "pattern_type": "stix",
            "valid_from": "2026-05-19T01:12:39.000Z",
```

```
            "created_by_ref": "identity--b3e01e69-b67d-5d89-bc59-d5f39a05ea8b",
            "object_marking_refs": [
                "marking-definition--94868c89-83c2-464b-929b-a1a8aa3c8487"
            ]
        }
    ]
}
```


8. MITRE ATT&CK Mapping

Tactic	Technique	ID
Initial Access, Persistence, Privilege Escalation, Defense Evasion	Valid Accounts: Cloud Accounts	T1078.004
Persistence, Privilege Escalation	Account Manipulation: Additional Cloud Roles	T1098.003
Persistence, Privilege Escalation	Domain or Tenant Policy Modification: Trust Modification	T1484.002
Credential Access	Steal Application Access Token	T1528
Credential Access, Lateral Movement	Forge Web Credentials: SAML Tokens	T1606.002
Exfiltration	Transfer Data to Cloud Account	T1537
Impact	Inhibit System Recovery	T1490
Impact	Data Encrypted for Impact	T1486
Impact	Financial Theft	T1657

T1528 and T1486 are the platform's own confirmed answers to the two scored classification tasks (4 and 7). T1078.004, T1098.001 and T1537 appear as tags on this operation's SIEM panel. T1484.002, T1606.002, T1490 and T1657 are stated here because each is evidenced directly by a record recovered in the scored tasks — the federation change, the impersonating sign-in, the vault deletion and the Teams ransom message — rather than inferred from the scenario narrative.

9. Impact & Containment

Impact: total tenant compromise with both confidentiality and availability loss. Roughly 768 GB of freight-archive data was egressed to attacker infrastructure and must be treated as breached. Every snapshot, restore point and the Recovery Services vault were destroyed, so the organisation cannot restore from backup, and the surviving storage is encrypted with a key held in an attacker-controlled key vault. Worst of all, the federation trust means the attacker can still mint a token for any identity in the directory: until that trust is removed, resetting every password in the tenant changes nothing. Containment steps, in priority order:

1. Remove the federated domain kaldberg-sync-trust[.]com and its token-signing certificate from the tenant, then audit every federated and verified domain — no other step matters while the

trust stands.
2. Disable svc-aadc-sync, rotate its credentials, and remove its Global Administrator role and the Owner assignment at subscription scope; block interactive sign-in for all directory-sync identities.
3. Rotate both storage account keys on kaldbergprodblob01 immediately and move access to Entra-based RBAC with shared-key authorisation disabled, since the stolen keys remain valid until rotated.
4. Block 109.100.14[.]222, 14.103.118[.]198, 103.191.14[.]243 and 1.214.214[.]114, and revoke all refresh tokens and sessions tenant-wide, including for harriet.voss.
5. Engage legal and privacy on breach notification for the 768 GB of freight data, and open a recovery workstream that assumes no backups exist — including whether the customer-managed key can be recovered from the attacker key vault or the data must be treated as lost.

10. Conclusion & Recommendations

Final verdict: True Positive, and the most severe case in this portfolio. In five hours a directory-synchronisation account with standing Global Administrator and no MFA was used to federate an attacker domain, elevate to Owner over the subscription, steal the storage account keys, egress 768 GB with AzCopy, delete every recovery path, re-encrypt the survivors with a key the company does not control, and extort the business over Teams as a forged employee. All 8 scored tasks were resolved and this was the first completion of the operation on the platform.

Two lessons carry beyond this scenario. The first is that ransomware no longer needs ransomware: every impact action here was a legitimate Azure API call, so any detection strategy built on malicious binaries would have seen nothing. The second concerns where detection value sits — the four attacker addresses are all flagged by multiple vendors, yet blocking them would have been closing the door after each stage, while the federated domain that gave the operator permanent, identity-independent access is flagged by nobody. What caught this case was configuration-state monitoring: an identity that should never sign in interactively doing so, a new federated domain, an Owner assignment, a listKeys call followed by a SharedKey read from the internet.

Recommendations:

1. Alert on any interactive sign-in by a directory-synchronisation or other non-human identity, and remove standing Global Administrator from service accounts in favour of just-in-time elevation.
2. Treat federated-domain creation and token-signing certificate changes as break-glass events: alert immediately, require multi-person approval, and audit the federation configuration on a schedule.
3. Disable shared-key authorisation on storage accounts and use Entra RBAC with managed identities, so a control-plane role cannot be converted into unrestricted data-plane access via listKeys.

4. Alert on storageAccounts/listKeys, especially when followed by SharedKey reads from external addresses or by an AzCopy user agent.
5. Protect backups with immutability and resource locks, and alert on deletion of Recovery Services vaults, snapshots or restore points — in this case that alert would have preceded the encryption by minutes.
6. Restrict which key vaults may supply customer-managed keys to storage encryption scopes, and alert on any encryption-scope change on production storage.
7. Enforce MFA and Conditional Access on every privileged identity without exception, including the sync account, which is the single control that would have stopped this at 01:12.

11. Evidence / Screenshots

Figure	Caption	Referenced in
Figure 1	The completed Advanced operation — 8/8 tasks, first completion on the platform — with the five Critical detection rules the tenant's monitoring fired	Sections 3, 4
Figure 2	The four Critical records: the no-MFA sign-in by the sync identity, the federated-domain change, the 768 GB SharedKey bulk read and the Defender for Cloud backup-destruction alert	Tasks 2, 3, 5, 6
Figure 3	The complete seven-event kill chain in time order, from initial access at 01:12:39 to the Teams extortion at 06:14:47	Sections 4, 6
Figure 4	Close view of the exfiltration and impact records: AzCopy/10.25.1 with AuthenticationType=SharedKey, then vault deletion and the customer-managed key applied to kaldbergprodblob01	Tasks 5, 6, 7
Figure 5	The Owner assignment at subscription scope and the federated sign-in impersonating harriet.voss via issuer kaldberg-sync-trust.com	Tasks 3, 8

Figure 1. The completed Advanced operation — 8/8 tasks, first completion on the platform — with the five Critical detection rules the tenant's monitoring fired.

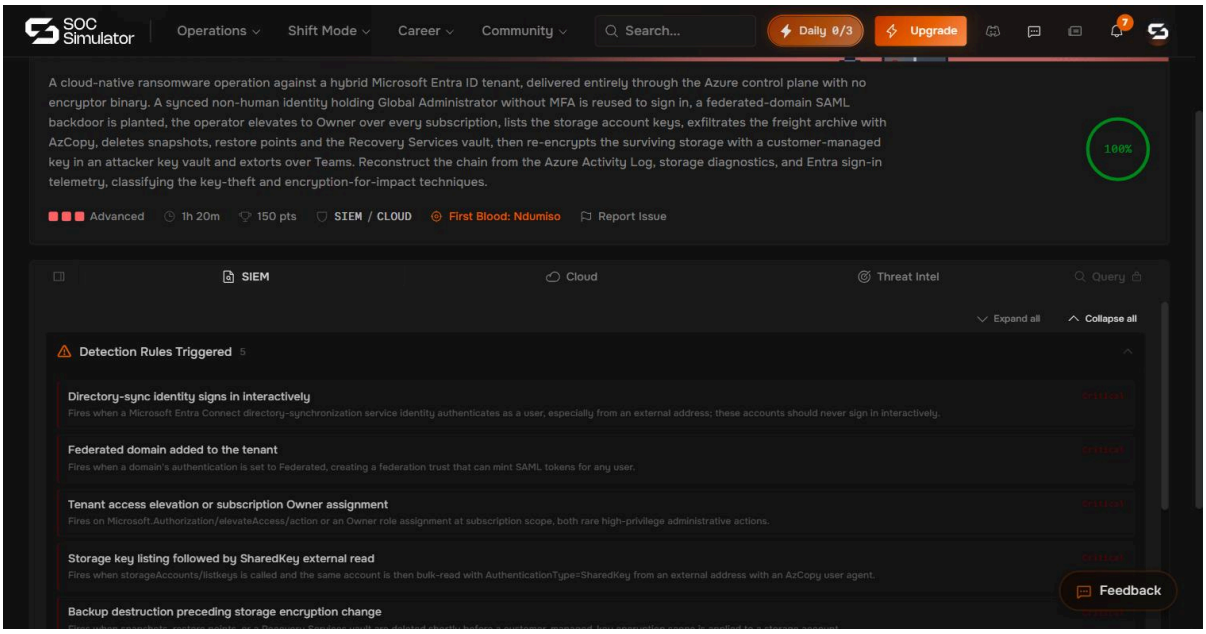


Figure 2. The four Critical records: the no-MFA sign-in by the sync identity, the federated-domain change, the 768 GB SharedKey bulk read and the Defender for Cloud backup-destruction alert.

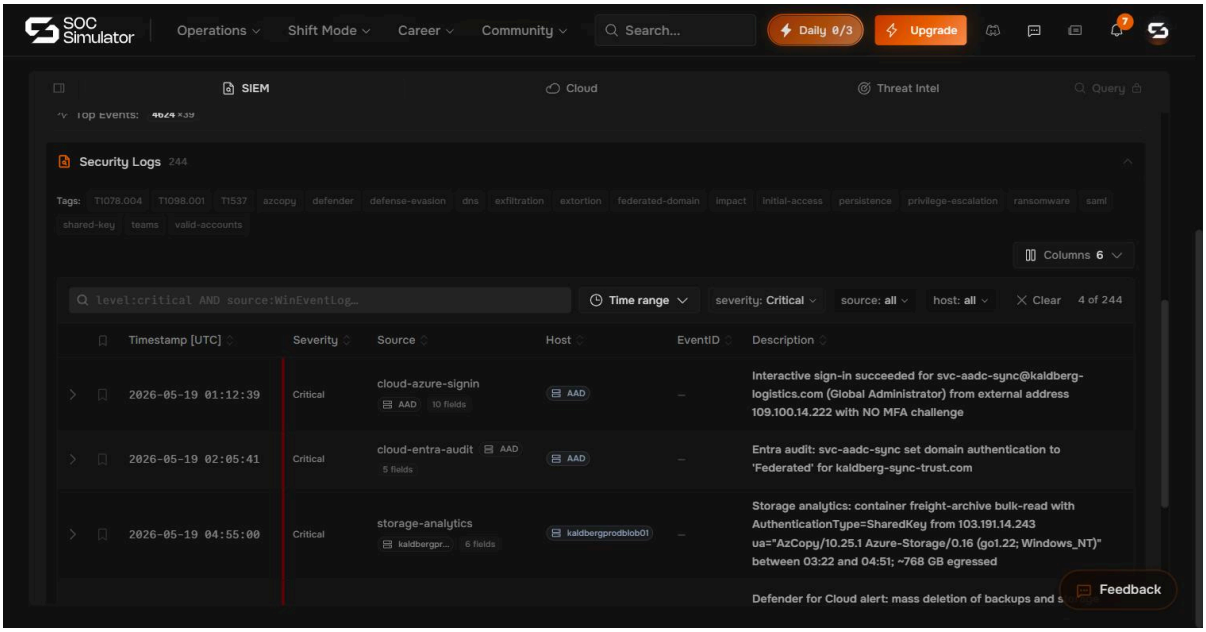


Figure 3. The complete seven-event kill chain in time order, from initial access at 01:12:39 to the Teams extortion at 06:14:47.

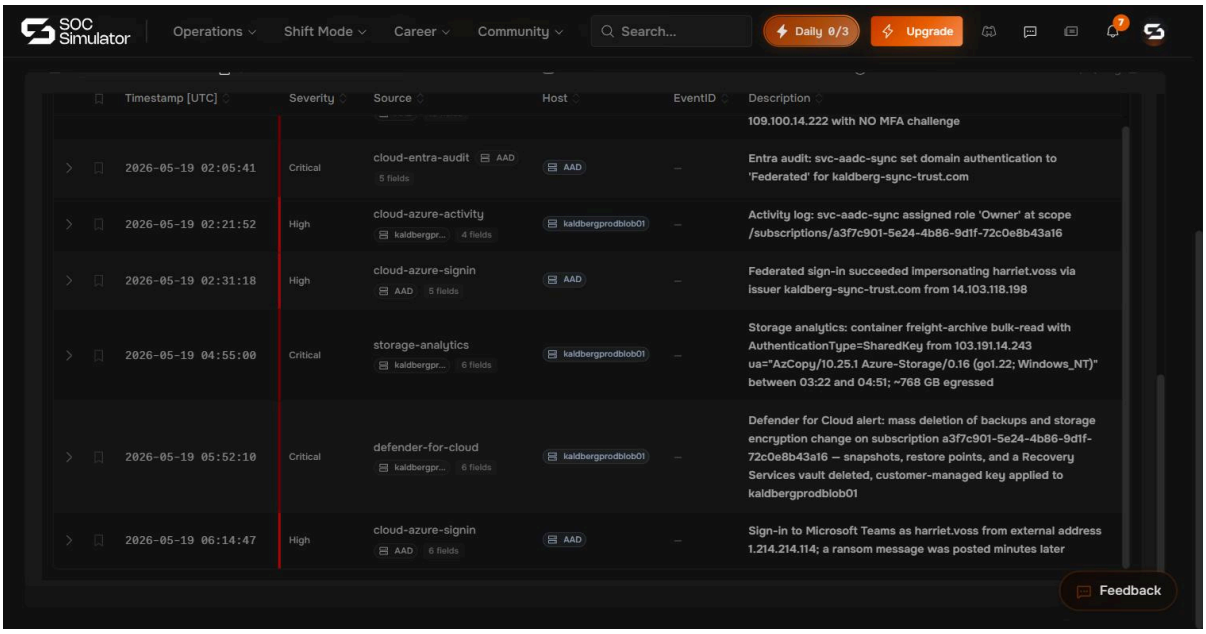


Figure 4. Close view of the exfiltration and impact records: AzCopy/10.25.1 with AuthenticationType=SharedKey, then vault deletion and the customer-managed key applied to kaldbergprodblob01.

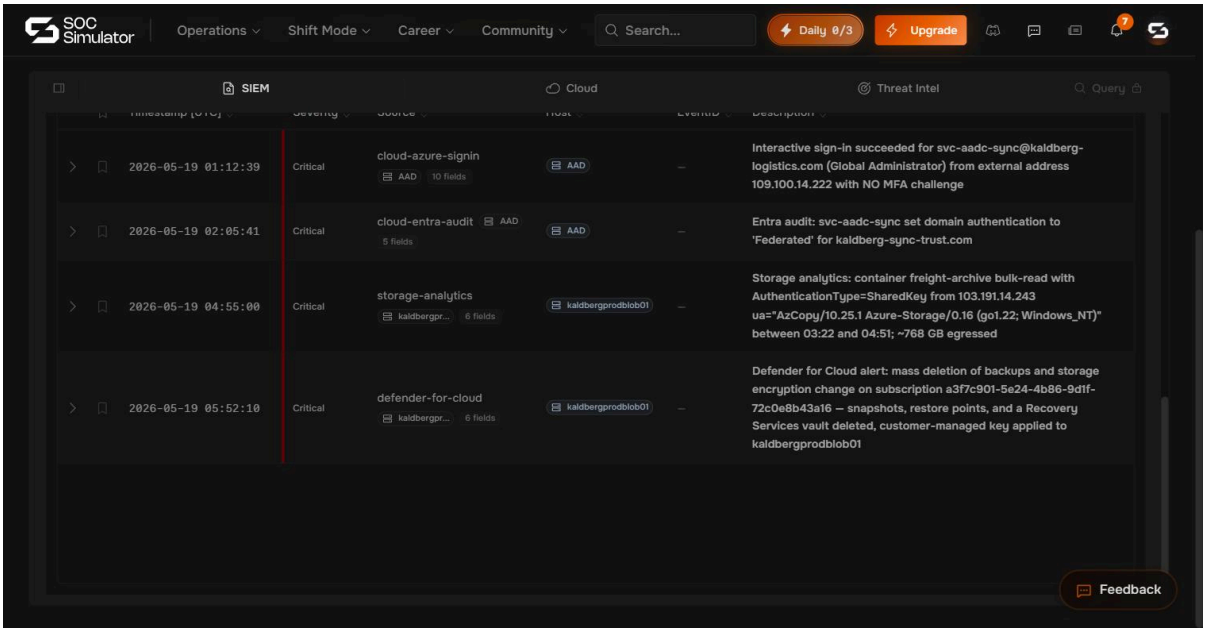


Figure 5. The Owner assignment at subscription scope and the federated sign-in impersonating harriet.voss via issuer kaldberg-sync-trust.com.

